

Cybersecurity
(T510039402)

Guest Lecture, 22 April 2026

Jukka Ruohonen

The Topic

- ▶ Learning Objectives – Content: “The purpose of the course is to give an understanding of cybersecurity concepts, activities and challenges. The course provides both an engineering and practical perspective of cybersecurity and **ethical** hacking.”
- ▶ To this end, the guest lecture will be about privacy and data protection, including the famous General Data Protection Regulation (GDPR) of the European Union

A Question

How would you define the term **privacy**?

What is Privacy? (1/2)

- ▶ The following six properties (P) appear frequently in the legal literature (as outlined in the classical article by Solove 2002):
 - ▶ P₁: The **right** to be left alone
 - ▶ P₂: The **ability** to shield oneself from unwanted access
 - ▶ P₃: The **concealment** of certain matters from others
 - ▶ P₄: **Control** over personal information
 - ▶ P₅: The **protection** of personality, individuality, and dignity
 - ▶ P₆: Control over **intimate** relationships and aspects of life
- ▶ The properties may seem deceptively simple at first glance
 - When scratching the surface, however, each property is extremely difficult philosophically, legally, and politically
- ▶ Roughly: if $\mathcal{P} = \{P_1 \cup P_2 \cup \dots \cup P_6\}$, then:
 $\implies \mathcal{P}$ is a fundamental **human right**

What is Privacy? (2/2)

- ▶ Thus, privacy is a philosophical and legal concept
 - **Subjective right**, which is given by **objective law**
- ▶ **Human rights** perspectives focus on P_1 , P_5 , and P_6
- ▶ In **computer science** the focus is typically on P_2 and P_3
 - Confidentiality, encryption, anonymization, etc.
 - Here, it is important to emphasize that confidentiality does *not* equal privacy, but it is a component of privacy
- ▶ **Data protection** focuses on P_4 , P_5 , and P_t in particular
 - Both security and data protection are necessary for privacy!

Privacy and Confidentiality

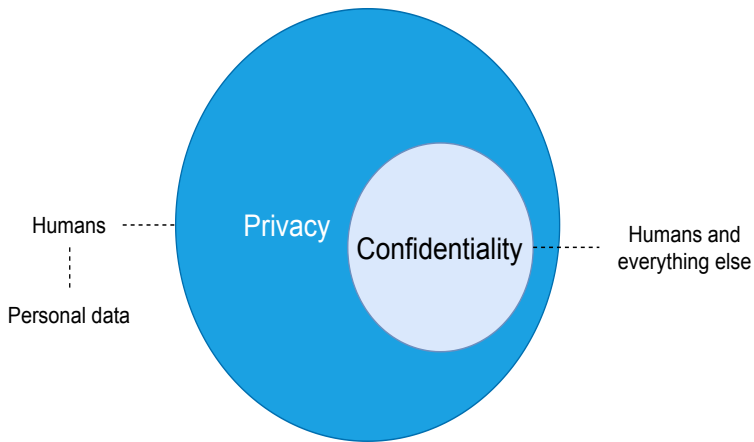


Figure 1: A Superset and a Subset

Privacy and Data Protection

- ▶ For instance, data protection requirements (e.g., accuracy and security of personal data processing) apply even when there are no violations of, or interference with, privacy

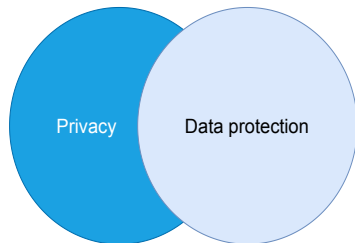


Figure 2: Overlapping But Not the Same

Fundamental Rights Perspective

- ▶ Privacy is present in the **Universal Declaration of Human Rights**, established in 1948 by the United Nations
 - *“No one shall be subjected to arbitrary interference with his privacy, family, home or correspondence, nor to attacks upon his honour and reputation (Article 12 in UN 1948)”*
- ▶ Many countries also have privacy in their **constitutions**
- ▶ Both privacy (or, rather, a right to “private life”) and data protection are fundamental rights also in the **European Union** (Articles 7 and 8 in EU 2012)
 - From a legal perspective, the definition of data protection as a fundamental right was perhaps more important than the enactment of the GDPR according to many legal scholars

Further Dimensions

- ▶ There are many further dimensions to privacy
- ▶ For instance, spatial and physiological privacy
 - Public spaces, private property, genetics ($\sim P_6$), etc.
- ▶ Also important to stress that privacy aspects related to **employment** and workplaces are covered in separate laws
- ▶ In many countries some issues belong also to the **criminal law**



Figure 3: Source: Wikipedia (CC BY-SA)

A textbook

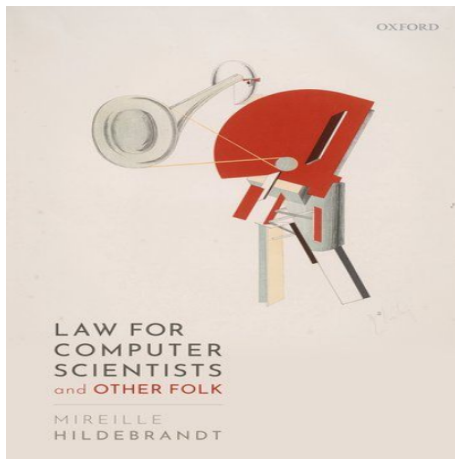
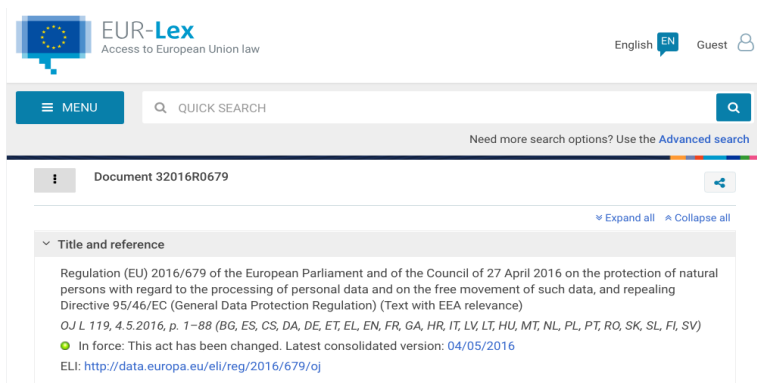


Figure 4: <https://lawforcomputerscientists.pubpub.org/>

Common Privacy Sins in Software Engineering

- ▶ Shastri et al. (2019) listed the following seven commonplace “**privacy sins**” in the context of software engineering:
 1. Storing data forever
 2. Reusing data indiscriminately
 3. Walled gardens and black markets
 4. Risk-agnostic data processing
 5. Hidden data breaches
 6. Unexplainable decisions
 7. Security as a secondary goal
- ▶ The GDPR addresses all of these sins
- ▶ The GDPR is also a **risk-based regulation**

The GDPR (1/2)



The screenshot shows the EUR-Lex website interface. At the top, there is a header with the EUR-Lex logo and the text "Access to European Union law". To the right, there are links for "English EN" and "Guest" with a user icon. Below the header, there is a navigation bar with a "MENU" button and a "QUICK SEARCH" input field. A search button with a magnifying glass icon is also present. Below the navigation bar, there is a message: "Need more search options? Use the [Advanced search](#)". The main content area displays the document "Document 32016R0679". Below the document title, there are links for "Expand all" and "Collapse all". The document content is organized into sections, with the first section titled "Title and reference". This section contains the following text: "Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (Text with EEA relevance)". Below this, it states "OJ L 119, 4.5.2016, p. 1–88 (BG, ES, CS, DA, DE, ET, EL, EN, FR, GA, HR, IT, LV, LT, HU, MT, NL, PL, PT, RO, SK, SL, FI, SV)". A green circle icon indicates "In force: This act has been changed. Latest consolidated version: [04/05/2016](#)". Finally, it provides the ELI link: "ELI: <http://data.europa.eu/eli/reg/2016/679/oj>".

Figure 5: <https://eur-lex.europa.eu/eli/reg/2016/679/oj>

The GDPR (2/2)

- ▶ At the time of lecturing, some aspects of the GDPR are being renegotiated in the EU via the so-called **digital omnibus**
- ▶ Thus, keep in mind that some of the legal aspects may change in the nearby future, although not necessarily that much with respect to the fundamental aspects

Politics

- ▶ The GDPR was allegedly the EU's **most lobbied law** in the late 2010s, and probably still is the most lobbied law
- ▶ According to Hildén (2019), the heavy lobbying by private sector actors, civil society groups, third-party countries, and others decreased the GDPR's overall legitimacy
- ▶ Later on, problems in the regulation's enforcement, alleged or real adoption problems, and compliance by small- and medium-sized enterprises have been on the political agenda
- ▶ It should be also emphasized that the regulation's goals were twofold: to **protect natural persons** and to facilitate the **free flow of personal data** across the union
 - Thus, to some extent, the GDPR can also be seen as an enabler for a fair European data economy

What Changed in the Big Picture?

1. Data subjects' **rights** increased
2. Data controllers' (and processors') **duties** increased
3. Data protection authorities' **power** increased
4. European **harmonization** improved

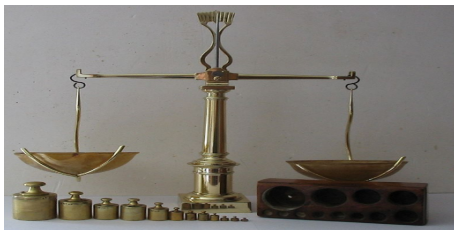


Figure 6: Source: Wikipedia (CC BY-SA)

National Adaptations

- ▶ The GDPR is a **regulation**; unlike EU directives, it is directly applicable EU law at the member states' jurisdictions
 - This point underlines the harmonization
- ▶ However, there is still some leeway for the member states, and, therefore, most member states have made a national data protection law (or, rather, updated an existing one)
 - In particular, flexibility is present with respect to legal obligations and public interests (Article 6), sensitive personal data (Article 9), and criminal matters (Article 10)
 - In addition, restrictions to the scope and details can be done on matters related to national security, defense, protection of judicial independence, and so forth (Article 23)

Governance (1/2)

- ▶ The governance of data protection in the EU follows the same overall model that was briefly discussed in the previous lecture with respect to cyber security
- ▶ In each country there is a public sector **data protection authority** (DPA) and EU-level coordination is done through the **European Data Protection Board** (EDPB)¹
 - Though, in Germany there are many DPAs
- ▶ Governance has also been an obstacle in the GDPR's enforcement (Ruohonen & Hjerpe 2022)
- ▶ Further note that there are alternative data protection EU laws for law enforcement and EU institutions

¹ https://www.edpb.europa.eu/edpb_en

Governance (2/2)

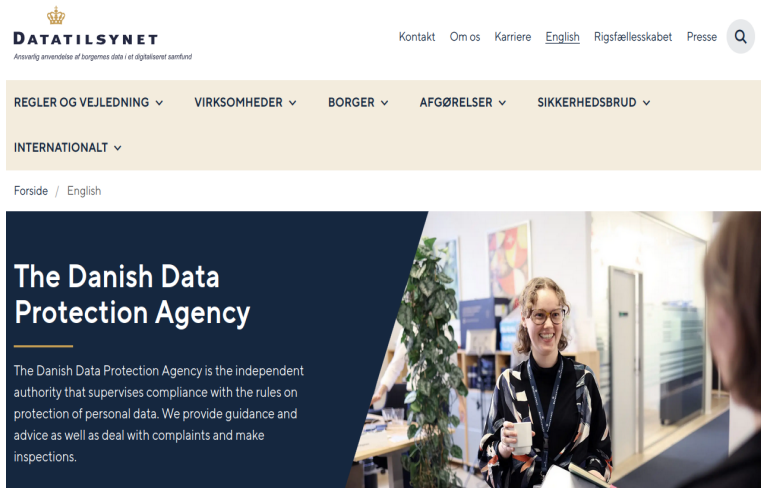


Figure 7: <https://www.datatilsynet.dk/english>

Personal Data

- ▶ Article 4(1): “*‘personal data’ means any information relating to an **identified or identifiable** natural person*”
 - Thus, the scope is much wider than with the notion of personally identifiable information (PII) used in the United States and elsewhere
- ▶ Article 4(2): *‘processing’ means any operation or set of operations which is performed on personal data or on sets of personal data, **whether or not by automated means**, such as collection, recording, organisation, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction*
 - Note that manual processing is in the scope too

Sensitive Personal Data (1/2)

- ▶ Article 9(1): *“Processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, data concerning health or data concerning a natural person’s sex life or sexual orientation shall be prohibited”*
- ▶ Though, exemptions are listed in Article 9(2); to put aside legal obligations of public sector bodies, another consent may be required to processes sensitive personal data
 - It may be possible to also process such data legally in case a person has made it public (cf. social media)

Sensitive Personal Data (2/2)

Note: This is a marked up excerpt of https://www.iab.com/wp-content/uploads/2017/11/IAB_Tech_Lab_Content_Taxonomy_V2_Final_2017-11.xlsx. Yellow highlighting denotes categories that likely to be **GDPR Article 9** “special category” data identifiers in RTB bid requests. Grey highlighting denotes data that might be “special category” data. Other items of interest are marked in blue.

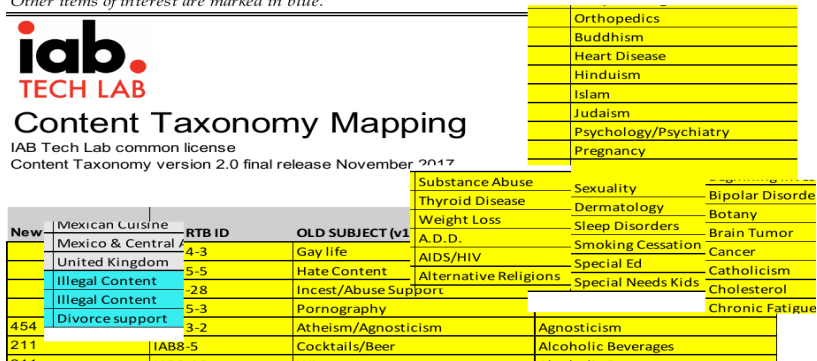


Figure 8: <https://brave.com/wp-content/uploads/2019/01/IAB-taxonomy-v1-excerpted-and-marked-up.pdf>

Controllers and Processors

- ▶ Articles 4(7), 4(8), 24, 26, 28, and 29
- ▶ Roughly: a data **controller** is responsible for the lawfulness and purpose (“why” and “how”), whereas a data **processor** processes personal data on behalf of the data controller
⇒ Usually a contract or some legally binding arrangement
- ▶ There are also joint controllers
- ▶ In general, controllers and processors are related to supply-chains; in case you hold personal data, you are a controller who can outsource processing to third-parties

Extraterritoriality

- ▶ The GDPR is an **extraterritorial law**
- ▶ The regulation applies to organizations controlling or processing of personal data inside or outside of the EU
- ▶ As clarified in Article 3, merely offering goods or services to Europeans (that is, European natural persons) suffices
- ▶ Extraterritoriality has been a source of major international schisms as well as high-profile court cases

International Transfers

- ▶ Related to extraterritoriality are international transfers of data, which have been a major legal and political issue
- ▶ The legal details are complex, but, in general, a transfer of personal data to a country outside of the EU is legally possible in case the EU-level authorities have determined that the country to which personal data is transferred has adequate levels of personal data protection

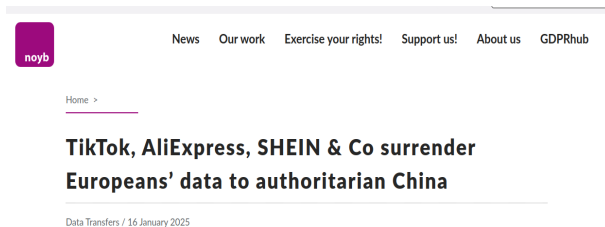


Figure 9: <https://noyb.eu/en/>

[tiktok-aliexpress-shein-co-surrender-europeans-data-authoritarian-china](https://noyb.eu/en/tiktok-aliexpress-shein-co-surrender-europeans-data-authoritarian-china)

Informational Self-Determination

- ▶ The GDPR is primarily a **data protection** (DP) regulation
 - DP $\neq$ privacy; DP is necessary but not sufficient for privacy
- ▶ Therefore, P₄, P₅, and P₆ carry a specific emphasis
 - ⇒ The concept of **informational self-determination**; everyone has a fundamental (but not absolute) right to determine how their data is collected and used
- ▶ Informational self-determination provides the foundation for **consent** in the data protection context
- ▶ Informational self-determination became famous with the 1983 decision of the German Constitutional Court²

² <https://freiheitsfoo.de/census-act/>

Lawfulness of Processing

- ▶ However, consent is only one way to legally process personal data under the GDPR
 - You must always pick one (and only one) legal basis
- ▶ There are six possibilities listed in Article 6:
 1. **Consent** (note that it must be informed)
 2. **Contract** (e.g., employment)
 3. **Legal obligations** (e.g., law enforcement)
 4. **Vital interests** (e.g., healthcare emergencies)
 5. **Public interests** (e.g., education)
 6. **Legitimate interests** (e.g., marketing)
- ▶ Of these, the last one is controversial; using it generally requires balancing the interests of natural persons against these so-called “legitimate interests”

Principles of Processing (1/2)

- ▶ The GDPR's recital 4: *“The processing of personal data should be designed to **serve mankind**. The right to the protection of personal data is **not an absolute right**; it must be considered in relation to its function in society and be **balanced** against other fundamental rights, in accordance with the principle of **proportionality**.”*

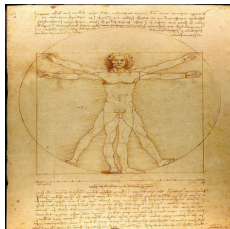


Figure 10: Source: Wikipedia (CC BY-SA)

Principles of Processing (2/2)

- ▶ Furthermore, Article 5 lists seven general principles:
 1. **Lawful, fair, and transparent** processing
 2. Only for **specific purposes and not for other purposes**
 3. **Data minimization**; only what is necessary
 4. **Accuracy**; only accurate personal data should be processed
 5. **Identifiability** only for a limited amount of time
 6. **Security** of processing must be guaranteed
 7. **Accountability**: controllers and processors are legally liable
- ▶ Although these are very high-level principles, their violations have frequently been used by regulators for justifying enforcement fines

Articles Referenced in Enforcement Fines

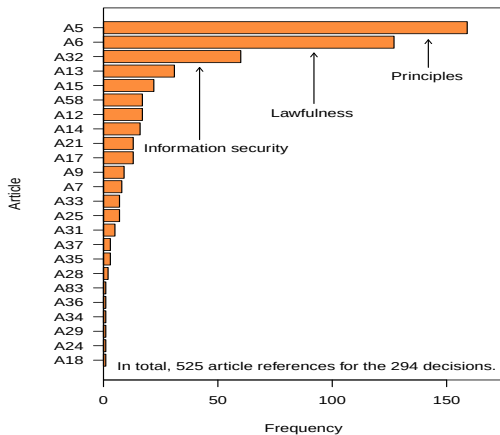


Figure 11: Ruohonen & Hjerpe (2022, Fig. 7)

What Violations Were Present in This Famous Case?

Facebook–Cambridge Analytica data scandal

[Article](#) [Talk](#) [Read](#) [Edit](#) [View history](#) [Tools](#)

From Wikipedia, the free encyclopedia

In the 2010s, personal data belonging to millions of [Facebook](#) users was collected by British consulting firm [Cambridge Analytica](#) for [political advertising](#), without having the [informed consent](#) of users for that purpose.^[1]

The data was collected through an app called "This Is Your Digital Life", developed by data scientist [Aleksandr Kogan](#) and his company Global Science Research in 2013.^[2] The app consisted of a series of questions to build psychological profiles on users, and collected the personal data of the users' Facebook friends via Facebook's Open Graph platform.^[2] The app harvested the data of up to 87 million Facebook profiles.^[2] Cambridge Analytica used the data to analytically assist the 2016 presidential campaigns of [Ted Cruz](#) and [Donald Trump](#).^{[3][4]} Cambridge Analytica was also widely accused of interfering with the [Brexit referendum](#), although the official investigation recognised that the company was not involved "beyond some initial enquiries" and that "no significant breaches" took place.^{[5][6]}

This article is part of a series about

Meta Platforms



[History \(Instagram · WhatsApp\) · Acquisitions](#)

Products and services

[Facebook](#) [\[show\]](#)

Other products [\[show\]](#)

People

Executives and board members [\[show\]](#)

Notable employees [\[show\]](#)

Related organizations [\[show\]](#)

Business

[Criticism](#) [\[show\]](#)

Figure 12: https://en.wikipedia.org/wiki/Facebook%E2%80%93Cambridge_Analytica_data_scandal

Privacy from a Security Perspective (1/3)

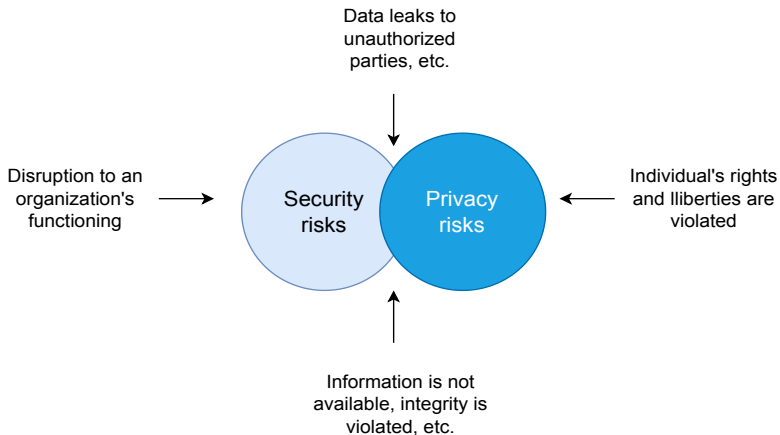


Figure 13: Some Security and Privacy Risks

Privacy from a Security Perspective (2/3)

- Sometimes there may be a seemingly artificial conflict between security and privacy requirements

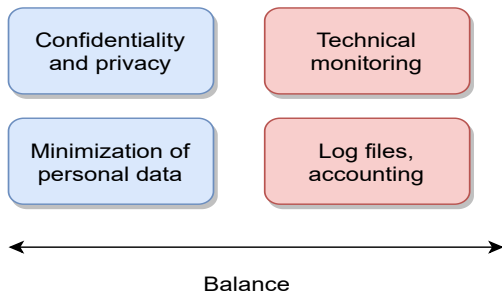


Figure 14: Balancing Between Security and Privacy Requirements

Privacy from a Security Perspective (3/3)

- ▶ However, the GDPR does not explicitly tell how security should be guaranteed; it is generally up to software and other engineers to come up with the *appropriate* solutions
- ▶ Article 32(1): *“Taking into account the **state of the art**, the **costs** of implementation and the **nature, scope, context** and **purposes** of processing as well as the **risk** of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk”*
 - Then, the Article continues to note pseudonymization, encryption, the CIA triad, resilience, and testing, among other things, but does not go into technical details

Group Work (20 minutes)

- ▶ Take one of the enforcement cases from an online tracker³ and explain the fundamental reason for the given enforcement
 - No strict legal interpretations are required; merely discuss the fundamental reason in your own words
 - How the enforcement could have been avoided?
 - What implications the given case entails for others?
 - Feel free to use Google Translate or something alike

³ <https://enforcementtracker.com/>

Privacy Engineering

- ▶ Privacy engineering is an emerging concept
 - It is a *“field of research and practice that designs, implements, adapts, and evaluates theories, methods, techniques, and tools to systematically capture and address privacy issues when developing sociotechnical systems”* (Gürses. & del Alamo 2016)
- ▶ Spiekermann & Cranor (2009) emphasize a need to move from a commonplace **“privacy-by-policy”** approach to a more software engineering focused **“privacy-by-architecture”**
 - In other words, also software architectures should be ideally designed with privacy in mind

Privacy-by-Design

- ▶ The concept was introduced by Ann Cavoukian in 1995
- ▶ The foundational principles followed later (Cavoukian 2009):
 - ▶ P₁: **Proactive** not reactive; preventative not remedial
 - ▶ P₂: Privacy as the **default** setting
 - ▶ P₃: Privacy embedded into **design**
 - ▶ P₄: Full **functionality** – positive-sum, not zero-sum
 - ▶ P₅: End-to-end **security** – full lifecycle protection
 - ▶ P₆: Visibility and **transparency** – keep it open
 - ▶ P₇: Respect for user privacy – keep it **user-centric**
- ▶ On one hand, closely related to the GDPR, and on the other, to the so-called **privacy enhancing technologies** (PETs)

Frameworks (1/5)

- ▶ Over the years, some frameworks and even standards have been developed for privacy engineering
- ▶ Of these, NIST's (2021) privacy control framework is decent already because it aligns quite closely with the GDPR's law-imposed obligations
- ▶ The NIST's framework is based on eight high-level *privacy controls*, which contain more fine-grained requirements
- ▶ The first control is **authority and purpose**: personal data can be collected only with a granted authority ($\implies$ legal basis under the GDPR) and it must be collected only for a specific purpose ($\implies$ purpose limitation in the GDPR)

Frameworks (2/5)

- ▶ The second privacy control is about **accountability, auditing,** and **risk management**: you are accountable for collecting, storing, and processing of personal data, and you should do audits and risk management (cf. $\implies$ data protection impact assessments under the GDPR; see Article 35)
 - Here, ENISA (2017) suggests using similar risk matrices (impact $\times$ probability) that were discussed in the third lecture
- ▶ The third control is about **data quality** and **integrity**: data about natural persons should be correct and it should be immutable for unauthorized parties
- ▶ The fourth privacy control is about **data minimization** and **data retention**: only collect what you need and do not store personal data indefinitely

Frameworks (3/5)

- ▶ The fifth control is about **participation** and **redress**: natural persons should be given access to their personal data; they should have a right to correct data about themselves; they should have a right to lodge complaints; and so on
- ▶ The sixth control is about **security**
- ▶ The seventh control is about **transparency**: at minimum, there should be privacy policies accessible to natural persons
- ▶ The eight and last control is about **use limitation**: among other things, sharing of personal data with third-parties can be done only under specific conditions

Frameworks (4/5)

- ▶ The so-called LINDDUN framework is a popular high-level framework pioneered by Wuyts (2015)
- ▶ The framework is based on six properties:
 1. **Linkability**: whether two objects are related
 2. **Identifiability**: possibility to identify an object
 3. **Non-repudiation**: evidence that a party cannot deny
 4. **Detectability**: whether an object exists
 5. **Disclosure**: exposure of information to unauthorized subjects
 6. **Unawareness**: user is unaware of data submitted
- ▶ The model can be used akin to threat modeling: each identified asset related to natural persons should be assessed against the six properties

Frameworks (5/5)

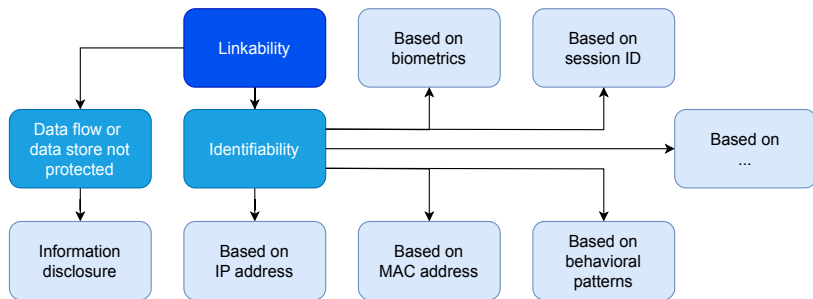


Figure 15: Linkability as an Example (Wuyts 2015, Fig. 3.3, p. 44)

Anonymization and Pseudonymization (1/4)

- ▶ **Identification** := ability to identify a data subject
- ▶ **De-identificaton** := a method that prevents re-identification
- ▶ **Anonymization** := optimally irreversible de-identification
- ▶ **Pseudonymization** := a de-identification method that either removes or replaces direct identifiers from data
 - In other words, *“'pseudonymisation' means the processing of personal data in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information [...]"* (GDPR, Article 4)

Anonymization and Pseudonymization (2/4)

- ▶ Important to understand: pseudonymization $\neq$ anonymization
- ▶ Three common elements for the evaluation of methods:
 1. **Singling out**: it is still possible to isolate some or all records relating to a given individual in a database
 2. **Linkability**: it is still possible to link at least two records relating to an individual in one or more databases
 3. **Inference**: it is possible to infer (with significant probability) a value of an attribute from the values of other attributes
- ▶ In general, pseudonymization only addresses linkability
 - Particularly identification via inference is not guaranteed
 - Thus, the focus is perhaps more on security

Anonymization and Pseudonymization (3/4)

- ▶ Several articles in the the GDPR emphasize pseudonymization
⇒ The GDPR does **not** apply to strictly anonymized data!
⇒ Furthermore: *“If the purposes for which a controller processes personal data do not or do no longer require the identification of a data subject by the controller, the controller shall not be obliged to maintain, acquire or process additional information in order to identify the data subject for the sole purpose of complying with this Regulation” (Article 11)*
- ▶ However, the accountability criterion applies also to pseudonymization ⇒ must be able to demonstrate this

Anonymization and Pseudonymization (4/4)

Table 1: Levels of De-identification (Hintze 2017)

	Identified	Identifiable	Article 11 identified	Anonymous
Directly linked	Yes	No	No	No
Re-identifiable	Yes	Yes	No	No
Personal data	Yes	Yes	Yes	No

Pseudonymization (1/2)

- ▶ Pseudonymization relates to so-called **reversible privacy**, which generally allows to securely switch between privacy-preserving and original representations of personal data
- ▶ Four commonly used techniques for pseudonymization:
 - (a) **encryption**, (b) **hashing**, (c) **masking**, (d) **tokenization**
 - In many practical implementations, all four may be required
 - All typically share a similar trait relating to a secret
 - For instance, processing credit card transactions uses encryption and tokenization (i.e., a card security code)

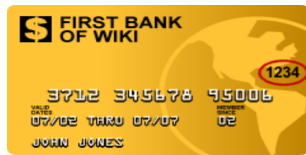


Figure 16: Source: Wikipedia (CC BY-SA)

Pseudonymization (2/2)

- ▶ **Masking** is a generic (old-fashioned?) pseudonymization method: at least all **direct identifiers** should be masked
 - These include names, addresses, social security numbers, license plates, IP addresses, device fingerprints, and so forth.
- ▶ Anonymization may be applied for other **quasi-identifiers**
 - For instance, gender, date of birth, postal code, income, etc.

Name	Gender	↦	Partially masked name	Gender
John Doe	M	↦	**** Doe	M
Jane Doe	F	↦	**** Doe	F

Anonymity (1/2)

- ▶ What is anonymity to begin with?
 - Many different notions and intuitive characterizations
 - Classical computer science definitions are provided by Pfitzmann and Köhntopp (2001)
- ▶ A definition: *"Anonymity is the state of being not identifiable within a set of subjects, the anonymity set."*
- ▶ A corollary: *"Anonymity is the stronger, the larger the respective anonymity set is and the more evenly distributed [...] the subjects within that set [are]."*

Anonymity (2/2)

1. If A denotes an anonymity set, $|A| \rightarrow \infty$ implies more anonymity for any given object (individual, device, etc.) in A
2. However, the size of the anonymity set does not guarantee anonymity by itself; $\Pr\{a \leq X \leq b\} = \int_a^b f(x)dx$ matters!
 - In other words, anonymity is also a **probability concept**
 - Therefore, classical measurement instruments include Shannon's information entropy and related concepts
 - Can be applied also to networks (graphs), etc.

Anonymization

- ▶ Anonymization seeks to ensure **irreversible de-identification**
 - A good anonymization solution should guarantee proper defenses against singling out, linkability, and inference attacks
- ▶ That said, many of the classical anonymization methods build upon pseudonymization-related ideas and concepts
 - Probability aspects are often either unaddressed or ignored
- ▶ Common anonymization methods include:
 - (a) **aggregation** and **re-coding**;
 - (b) **k -anonymity**;
 - (c) **ℓ -diversity** and **t -closeness**;
 - (d) **permutation** and **randomization**; and
 - (e) **differential privacy**

Aggregation

Table 2: Unaggregated

ID	Age	X
1	9	1390
2	39	50000
3	33	39
4	5	30000

Table 3: Aggregated

Age group	$\frac{1}{ A_i } \sum_{a \in A_i} A_i $
0 – 9	15695
30 – 39	25019.5

Re-coding

Table 4: Original coding

ID	Location	X
1	Lystrup	1390
2	Dragør	39
3	Frederiksberg	50000
4	Solbjerg	30000

Table 5: Re-coding

ID	Location	X
1	Aarhus	1390
2	Copenhagen	39
3	Copenhagen	50000
4	Aarhus	30000

k -anonymity (1/2)

- ▶ The so-called k -**anonymity** is more of a property of anonymity than an anonymization method in itself
- ▶ There is no universal method to obtain k -anonymity; masking and re-coding are the most common techniques
- ▶ **There is k -anonymity if data about each subject cannot be distinguished from at least $k - 1$ other subjects**
 - ⇒ Explicit framing particularly toward singling out; the maximum probability of re-identification is simply $1/k$
- ▶ While k -anonymity is increasingly used also in practical applications, robustness often remains somewhat unclear
 - The lack of well-defined methods one reason

k -anonymity (2/2)

Table 6: No k -anonymity

ID	Location	X
1	Copenhagen	1390
2	Copenhagen	39
3	Aalborg	50000
4	Aalborg	30000

Table 7: 2-anonymity for ID, Location, and X

ID	Location	X
*	Copenhagen	< 30000
*	Copenhagen	< 30000
*	Aalborg	≥ 30000
*	Aalborg	≥ 30000

ℓ -Diversity (1/3)

- ▶ Linkability is a problem for k -anonymity; with background data, it may be easy to break k -anonymity for any $k > 1$
- ▶ The so-called ℓ -**diversity** is one solution to these weaknesses
 - It was pioneered by Machanavajjhala et al. (2007)
- ▶ While the concept is rather involved mathematically, the essence is that **a k -anonymous dataset should contain also ℓ -number of values for any given sensitive attribute**
 - Generalizes to non-sensitive cases as well, of course

ℓ -Diversity (2/3)

- ▶ Although there are two identical rows ($\implies$ 2-anonymity), when we know a person's location or whether the inequality $X < 30000$ is true or false, we also know whether the person has a cardiovascular disease or a cancer

Table 8: 2-anonymity for ID, Location, X, and Condition

ID	Location	X	Condition
*	Copenhagen	< 30000	Cardiovascular
*	Copenhagen	< 30000	Cardiovascular
*	Aarhus	≥ 30000	Cancer
*	Aarhus	≥ 30000	Cancer

ℓ -Diversity (3/3)

- If we know that a person is from Aarhus, we no longer know that she has a cancer (i.e., without background information)

Table 9: 2-anonymity and 2-diversity for ID, Location, X, and Condition

ID	Location	X	Condition
*	Copenhagen	< 30000	Cardiovascular
*	Copenhagen	< 30000	Cardiovascular
*	Copenhagen	< 30000	Cancer
*	Copenhagen	< 30000	Cancer
*	Aarhus	$\geq$ 30000	Cancer
*	Aarhus	$\geq$ 30000	Cancer
*	Aarhus	$\geq$ 30000	Cardiovascular
*	Aarhus	$\geq$ 30000	Cardiovascular

Permutation and Randomization (1/2)

- ▶ Randomization is typically done by adding **noise** to attributes
- ▶ If $f^*(x) = f(x) + g(x)$, typical choices for $g(\cdot)$ include:
 - ▶ **Gaussian noise:** $f^*(x) = f(x) + N(0, \sigma^2)$, where $f(\cdot)$ denotes the desired output function for the attribute x , $N(\cdot)$ refers to the normal distribution, and σ^2 to the variance
 - ▶ **Laplace noise:** $f^*(x) = f(x) + L(0, \beta)$, where $L(\cdot)$ denotes a zero-location Laplace distribution, $L(0, \beta) = \exp(-|x|/\beta) / 2\beta$, with a positive scale (a.k.a. “diversity”) parameter $\beta > 0$
- ▶ **Attacks** are under active research for reverse engineering a given $f^*(\cdot)$, but, in general, these require deducing about the secret $g(\cdot)$ and any parameters this probability function takes
 - A simple machine learning analogy: deducing about missing completely at random (MCAR) vs. missing at random (MAR)

Permutation and Randomization (2/2)

- ▶ However, an attacker's task is often made much easier by commonly made mistakes and **non-rigorous** assumptions
- ▶ Many mistakes with permutation apply also to randomization
 - Adding noise only to one or a few **correlated** attributes
 - Adding **inconsistent noise** or out-of-bounds noise
 - Assuming that noise is enough; **sparsity** is a big issue
- ▶ Furthermore, linkability is often poorly considered
 - If we know that the spread of cardiovascular disease follows some imaginary distribution $h(\cdot)$ with parameters α and β in most populations, how hard will it be to deduce about $f^*(\cdot)$?
- ▶ **Differential privacy**, which is not covered in the present lecture, is the today's preferred randomization-based anonymization technique

On the Difficulties of Anonymization



**nature
communications**

Article | [Open Access](#) | Published: 23 July 2019

Estimating the success of re-identifications in incomplete datasets using generative models

Luc Rocher, Julien M. Hendrickx & Yves-Alexandre de Montjoye

Nature Communications **10**, Article number: 3069 (2019) | [Cite this article](#)

88k Accesses | **4** Citations | **1974** Altmetric | [Metrics](#)

from 0.84 to 0.97, with low false-discovery rate. Using our model, we find that 99.98% of Americans would be correctly re-identified in any dataset using 15 demographic attributes. Our results suggest that even heavily sampled anonymized datasets are unlikely to satisfy the modern standards for anonymization set forth by GDPR and seriously challenge the technical and legal adequacy of the de-identification release-and-forget model.

Figure 17:

<https://www.nature.com/articles/s41467-019-10933-3>

Rights Granted by the GDPR (1/2)

- ▶ R₁: The right to be **informed**
- ▶ R₂: The right to **access**
- ▶ R₃: The right to **rectification**
- ▶ R₄: The right to **erasure**
- ▶ R₅: The right to **cancel consent**
- ▶ R₆: The right to place **restrictions**
- ▶ R₇: The right to **object** processing
- ▶ R₈: The right to **portability**
- ▶ R₉: The right to individual **decision-making**
- ▶ R₁₀: The right to be informed about **data breaches**

Rights Granted by the GDPR (2/2)

- ▶ These can be roughly grouped into three categories:
 1. “**Informing**” $\mapsto \{R_1, R_{10}\} = \mathcal{R}_I$
 2. “**Data**” $\mapsto \{R_2, R_3, R_4, R_6, R_8\} = \mathcal{R}_D$
 3. “**Lawfulness**” $\mapsto \{R_5, R_7, R_9\} = \mathcal{R}_L$
- ▶ The group $\mathcal{R}_D$ is likely the most relevant for engineering
- ▶ However, there are various **overlaps** and logical **implications**
 - For instance: if consent is used as a legal basis and R_5 is exercised, deletion of personal data should follow in most cases ($\implies$ an overlap with R_4)
 - A further example: if R_6 is exercised, $R_3 \vee R_4$ cannot occur simultaneously (i.e., placing restrictions implies that the associated data cannot be deleted, modified, or updated)
- ▶ According to Hadar et al. (2018), software developers tend to overemphasize security and downplay rights

Rights and Requirements (1/7)

- ▶ The $\mathcal{R}_D$ group of rights implies some straightforward **functional requirements** for software architectures
 - At least operations at a **persistence layer** (cf. consent control, access, rectification, erasure, and restrictions) and **user interfaces** for these operations
- ▶ The right R_9 is debated but its general meaning is that one should have a right to *important* decisions made by a human instead of an automated AI/ML system
- ▶ The portability right R_8 too is still somewhat unclear; presently, it seems sufficient that JSON/CSV/etc. dumps can be delivered upon request

Rights and Requirements (2/7)

- ▶ When designing the persistence layer, general security design principles, such as **compartmentalization** and **isolation**, may provide high-level guidance
 - For instance, sensitive personal data (see p. 20) might be isolated into a separate database
 - Another example would be frontends; while also they may process some personal data (cf. clicks, A/B testing, etc. tied to IP addresses), the data involved is usually not as sensitive as some other personal data (cf. credit card data)

Rights and Requirements (3/7)

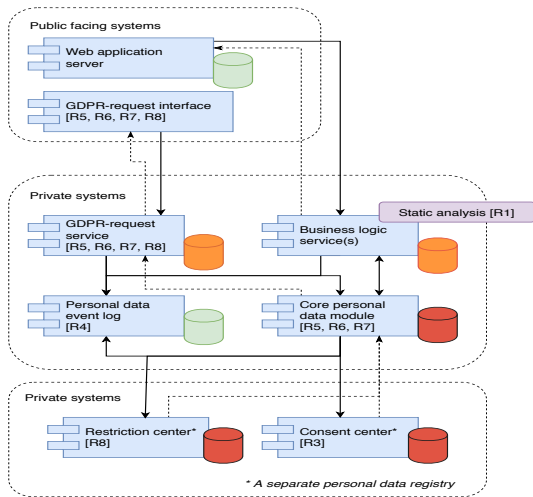


Figure 18: Hjerpe et al. (2019, Fig. 3)

Rights and Requirements (4/7)

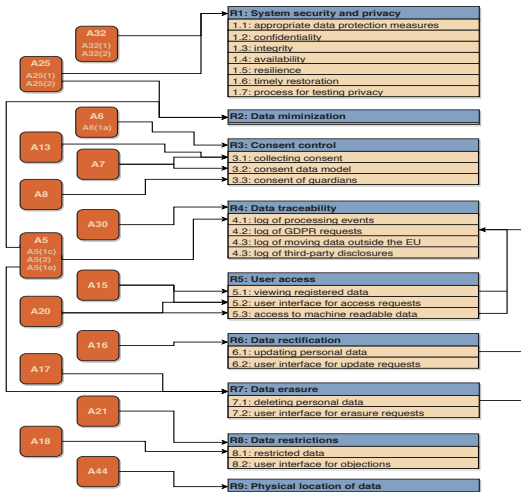


Figure 19: Hjerpe et al. (2019, Fig. 2)

Rights and Requirements (5/7)

- ▶ **Rigorous logging** is a further functional requirement
 - Article 30 mandates keeping extensive records of all personal data processing, including transfers to third-parties, security measures used, purpose of processing, categories of data processed, and so forth and so on
 - But recall the balancing trade-off on p. 32
- ▶ Note that **backups** can be challenging to handle because the $\mathcal{R}_D$ group should apply also to them; presently, it seems sufficient to leave backups intact but only insofar as these are done in a round-robin fashion (i.e., changes eventually propagate as old backups are deleted)

Rights and Requirements (6/7)

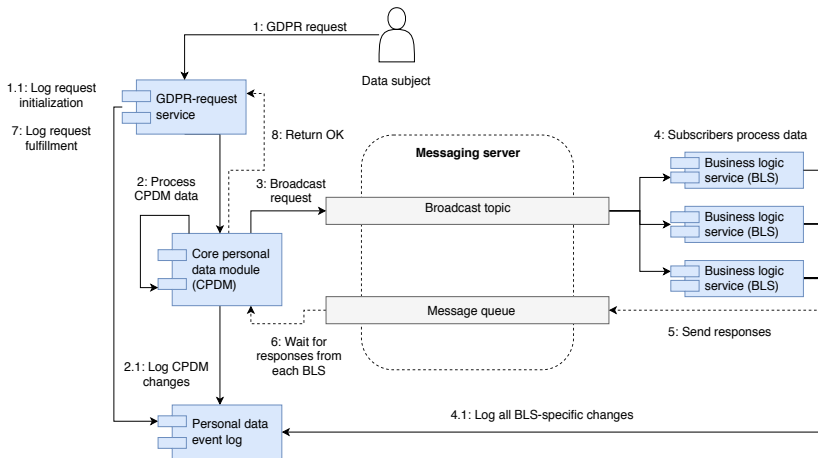


Figure 20: Hjerpe et al. (2019, Fig. 5)

Rights and Requirements (7/7)

- ▶ Though, it should be emphasized that the GDPR does not impose any specific software engineering requirements
- ▶ Thus, one should probably start from a contemplation whether implementing the functional requirements described is really necessary in each and every case
 - For instance, a small company could probably do the $\mathcal{R}_D$ group by manual means or by writing a few scripts in advance
- ▶ Having said that, architectural design can also serve as a **documentation**, which is required for the record-keeping obligation and other related things

Group Work (10 minutes)

- ▶ Consider a case involving a web-based online system for students to register into a Danish university
 - ▶ Then, try to answer to the following questions:
 - (a) What should be logged in terms of the GDPR?
 - (b) What should NOT be logged in terms of the GDPR?
- Justify both (a) and (b) with respect to:
- (c) Security
 - (d) Data protection

On Personal Data Governance More Generally

- ▶ Recently, new EU laws have been enacted for pooling of data into so-called **data spaces** (also known as data lakes)
 - While many of these data spaces are for non-personal data (e.g., manufacturing data, cultural heritage data, etc.), there are also ambitious plans for personal data; among these is the EU's so-called **digital wallet**
- ▶ Also non-governmental organizations – most notably **MyData**⁴ – have long developed similar ideas about controlling and transferring one's own personal data
 - Building upon R₈, these extend the rights on p. 61 into more comprehensive technical personal data ecosystems

⁴ <https://mydata.org/>

On Development and Production Environments

- ▶ In general, software developers seldom need to deal with “raw” personal data (e.g., using synthetic data is a good idea)

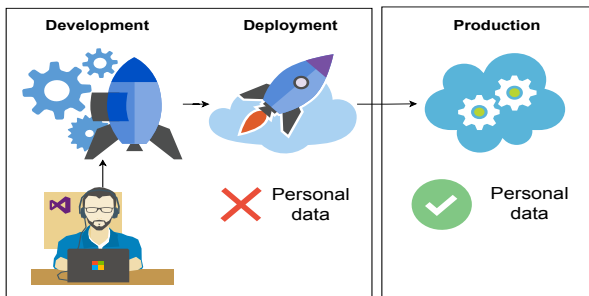


Figure 21: Staging and Production Environments

Risks and Requirements

- ▶ The GDPR's risk-based approach requires that also the requirements engineering phase is affected (cf. p. 33)
- ▶ Article 35 mandates **privacy impact assessments** in case there is a high-risk to natural persons
 - From this perspective, data protection is also a **non-functional requirement**, as is security of it
- ▶ Note that such assessments need to be also delivered to regulators in case of incidents

Organizational Requirements

- ▶ The impact assessments and risk analysis requirements in general are more on the side of organizational obligations
- ▶ A notable further organizational requirement is an obligation (Article 37) to designate a specific **data protection officer**
 - Although he or she is not personally liable, there are many legally imposed tasks specified in Articles 38 and 39
 - Among other things, he or she is responsible for coordinating with a data protection authority in case of incidents or other issues involving personal data
- ▶ Ciclosi & Massacci (2023) recommend going through the EDPB's (see p. 17) many guidelines in case you end up working as a such organizational data protection officer

Data Breach Notification Requirement

- ▶ An obligation to notify a DPA about data breaches further belongs to the organizational requirements imposed
- ▶ Article 33: *"In the case of a personal data breach, the controller shall without undue delay and, where feasible, **not later than 72 hours** after having become aware of it, notify the personal data breach to the supervisory authority"*
- ▶ In addition, according to Article 34, a **high-risk personal data breach** must also be communicated to the natural persons affected without further delay
 - A properly done prior risk analysis should help at determining what a high-risk breach is, but otherwise the GDPR does not provide clear guidance on this matter

Documentation Requirement

- ▶ The logging and record-keeping requirement noted on p. 67 imply an obligation to document all personal data processing
- ▶ While documentation may be done for internal purposes, communication of personal data protection to the outside world is commonly done with so-called **privacy policies**
 - Among other things: who is processing, where processing occurs, what is processed, how long data is retained, and so on
- ▶ A lot of research has been done to analyze privacy policies; the general conclusion is that these are still of poor quality
 - Roughly: either they are too short and vague or they are 10,000 word bulletproof legalese

Thank you

Questions?

References (1/3)

1. Solove, D. J. (2002): Conceptualizing Privacy. California Law Review 90, pp. 1087–1156; <http://scholarship.law.berkeley.edu/cgi/viewcontent.cgi?article=1408&context=californialawreview>
2. UN (1948): Universal Declaration of Human Rights. <https://www.un.org/en/about-us/universal-declaration-of-human-rights>
3. EU (2012): Charter of Fundamental Rights of the European Union. <https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:12012P/TXT>
4. Shastri, S. & Wasserman, M. & Chidambaram, V. (2019): The Seven Sins of Personal-Data Processing Systems under GDPR. USENIX HotCloud, <https://arxiv.org/pdf/1903.09305>
5. Hildén, J. (2019): The Politics of Datafication : The Influence of Lobbyists on the EU's Data Protection Reform and Its Consequences for the Legitimacy of the General Data Protection Regulation. University of Helsinki, <https://helda.helsinki.fi/items/3a3d8225-4eba-46e3-99b7-e8a20af381d5>
6. Ruohonen, J. & Hjerpe, K. (2022): The GDPR Enforcement Fines at Glance. Information Systems, <https://doi.org/10.1016/j.is.2021.101876>

References (2/3)

1. Gürses, S. & del Alamo, J. M. (2016): Privacy Engineering: Shaping an Emerging Field of Research and Practice. IEEE Security & Privacy 14(2) pp. 40–46, <https://ieeexplore.ieee.org/abstract/document/7448344>,
2. Spiekermann, S. & Cranor, L. F. (2009): Engineering Privacy. IEEE Transactions on Software Engineering 35(1), pp. 67–82. <https://ieeexplore.ieee.org/abstract/document/4657365>
3. Cavoukian, A. (2009): Privacy By Design: The 7 Foundational Principles, <https://www.ipc.on.ca/wp-content/uploads/Resources/7foundationalprinciples.pdf>
4. NIST (2021): Security and Privacy Controls for Federal Information Systems and Organizations. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>
5. ENISA (2017): Handbook on Security of Personal Data Processing. <https://www.enisa.europa.eu/sites/default/files/publications/WP2017%200-2-2-5%20GDPR%20Measures%20Handbook.pdf>
6. Wuyts, K. (2015): Privacy Threats in Software Architectures, KU Leuven, <https://lirias.kuleuven.be/1656390>

References (3/3)

1. Hintze, M. (2017): Viewing the GDPR Through a De-identification Lens: A Tool for Compliance, Clarification, and Consistency. International Data Privacy Law 8(1), pp. 86–101, <https://doi.org/10.1093/idpl/ix020>
2. Pfitzmann, A. & Köhntopp (2001): Anonymity, Unobservability, and Pseudonymity — A Proposal for Terminology, pp. 1–9, https://link.springer.com/chapter/10.1007/3-540-44702-4_1
3. Machanavajjhala, A. & Gehrke, J. & Kifer, D. & Venkitasubramaniam, M. (2007): ℓ -Diversity: Privacy Beyond k -Anonymity. ACM Transactions on Knowledge Discovery, 1(1), pp. 1–52, <https://www.truststc.org/pubs/465/L%20Diversity%20Privacy.pdf>
4. Hadar, I. et al. (2018): Privacy by Designers: Software Developers' Privacy Mindset. Empirical Software Engineering 23, pp. 259–289, <https://link.springer.com/article/10.1007/s10664-017-9517-1>
5. Hjerpe, K. & Ruohonen, J. & Leppänen, V. (2019): The General Data Protection Regulation: Requirements, Architectures, and Constraints. 27th International Requirements Engineering Conference (RE), pp. 265–275, <https://arxiv.org/pdf/1907.07498>
6. Ciclosi, F. & Massacci, F. (2023): The Data Protection Officer: A Ubiquitous Role That No One Really Knows. IEEE Security & Privacy 21(1), pp. 66–77, <https://ieeexplore.ieee.org/stamp/stamp.jsp?arnumber=9998077>